

Secure Server

1. Threat Model

This document defines the security design for an internet-facing Ubuntu server hosting a small internal web application, SSH administrative access, and basic audit logging.

1.1 Identified Threats

- Automated Scanning and Brute Force: Automated reconnaissance bots that continuously scan internet-facing servers for open ports, known CVEs, and default or weak credentials.
- Targeted External Attack / Ransomware: Motivated external attackers or ransomware operators who may use credential stuffing, phishing, or exploit known vulnerabilities to gain an initial foothold, then move toward data exfiltration, encryption, or extortion.
- Malicious Insider (Active Account): A current employee or administrator who abuses their active, authorized access for personal gain or sabotage.
- Disgruntled or Terminated Employee: A former employee whose access was not promptly revoked upon separation.

1.2 Protected Assets

- PII and Customer Data: Personally identifiable information belonging to employees and customers, including names, addresses, and related personal data.
- Proprietary Project and Development Data: Proprietary work product including in-development projects, internal documentation, and any source code or intellectual property hosted on or accessible from the server.
- Organizational Credentials and Financial Records: Organizational credentials, API keys, configuration files, and financial records.
- Audit Log Integrity: The integrity of audit and authentication logs is itself a critical asset.

1.3 Assumptions

- Remote Access from Untrusted Networks: Administrators connect remotely from home networks, which are considered untrusted by default. Consumer-grade routers, shared ISPs, and potentially shared devices preclude reliance on IP whitelisting as a meaningful control.
- Physical Access is Restricted: Physical console access to the server is restricted to the server's physical location only. Remote access occurs exclusively over SSH, and physical access serves as an independent accountability layer.
- Limited Budget and Security Expertise: The organization is newly formed with limited dedicated security budget and staff.
- No Dedicated Security Personnel: There is no dedicated security operations staff.

2. Minimal Services and Attack Surface

2.1 Required Services

- OpenSSH Server: SSH (port 22) — required for all remote administrative access. Will be hardened per Section 3.
- Web Server: Nginx or Apache (ports 80 and 443) — required to serve the internal web application over HTTP and HTTPS. One web server will be selected; both will not be installed simultaneously.
- Firewall (UFW): UFW (Uncomplicated Firewall) — configured with a default-deny inbound policy, permitting only ports 22, 80, and 443.
- Logging Daemons: systemd-journald and auditd
- Unattended-Upgrades: Configured for security-only automatic updates to reduce patching lag without requiring constant manual intervention.

2.2 Services to Disable or Remove

- Mail Transfer Agent (Postfix/Sendmail): Mail transfer agents (Postfix, Sendmail) are installed by default on many Ubuntu configurations and serve no function on this server.
- Avahi Daemon (mDNS/Service Discovery): Avahi enables mDNS-based service discovery designed for local networks. On an internet-facing server it serves no purpose and unnecessarily exposes service information.
- Bluetooth Services: Server hardware does not require Bluetooth. If present, associated services should be disabled.
- GUI and Graphical Remote Access: No graphical environment, VNC, or RDP services will be installed. Terminal access via SSH is sufficient for all administrative tasks and presents a significantly smaller attack surface than any graphical remote access solution.
- FTP Daemon: Traditional FTP transmits credentials and data in plaintext and is unnecessary here. Secure file transfer is handled by SFTP, which operates over the existing SSH connection at no additional attack surface cost.
- Samba/SMB/NFS: Windows file sharing protocols have no role on this server and would expose unnecessary network services.

3. Authentication and Access Control

3.1 SSH Authentication Policy

- Key-Based Authentication Only: Password-based SSH authentication will be disabled entirely in sshd_config. Passwords are vulnerable to brute force, credential stuffing, and reuse from external data breaches. Disabling them eliminates this entire class of attack. Key-based authentication requires possession of a private key that never traverses the network.
- Root SSH Login Disabled: Direct root login over SSH will be disabled. Root access is restricted to physical console access only. This design is deliberate: an administrator with remote root access and malicious intent could cause catastrophic damage with minimal accountability. Requiring physical presence for root-level actions creates an independent audit trail (physical surveillance, keycard logs, and witnesses) that cannot be tampered with remotely.
- Explicit Allow List: SSH access will be restricted to named admin accounts using the AllowUsers directive in sshd_config, ensuring that only explicitly authorized accounts can authenticate.

3.2 Admin Account Structure

- Individual Named Accounts: Each administrator will be issued a unique named account. Shared accounts are prohibited. This ensures every action logged on the system is attributable to a specific individual. In the event of an incident, there is no ambiguity about which administrator performed which action.
- Prompt Account Revocation: When an administrator's employment ends or their role changes, their account and associated SSH key are revoked immediately. Prompt offboarding is a direct control against the terminated employee threat identified in Section 1.
- Per-User SSH Key Pairs: Each administrator is issued a unique SSH key pair. Private keys must not be shared across devices or individuals. If a device holding a private key is lost or compromised, the associated public key is immediately removed from the server's `authorized_keys` file.

3.3 Privilege Escalation (sudo)

- Least Privilege via Scoped sudo: No administrator will be granted unrestricted sudo access by default. sudo privileges will be scoped to the specific commands required by each administrator's role.
- sudo Logging: All sudo commands are logged. This creates an auditable record of every privileged action, which is essential for detecting insider abuse and reconstructing post-incident timelines.
- Physical Presence for Root Operations: For operations that require root-level access not covered by scoped sudo, administrators must be physically present at the server. This prevents remote execution of the most destructive possible actions.

4. Patch and Update Strategy

4.1 Update Tiers

- Tier 1 — Automatic Security Updates: Ubuntu's unattended-upgrades package will be configured to automatically apply security-only updates from the Ubuntu security repository. These patches address actively exploited vulnerabilities where the risk of delayed patching outweighs the risk of breakage.
- Tier 2 — Manual Updates During Maintenance Window: General package updates, new software versions, kernel upgrades, and dependency changes will be applied manually during a defined maintenance window.

4.2 Maintenance Window and Testing

- Scheduled Maintenance Window: Non-critical updates will be applied during a scheduled maintenance window when user impact is minimized.
- Pre-Patch Snapshot: If the server is virtualized, a snapshot will be taken immediately before any Tier 2 update session.
- Post-Patch Verification: After applying updates, administrators will verify that the web server responds correctly, SSH accepts connections, and system logs show no new critical errors before closing the maintenance window.

4.3 Rollback Plan

- Snapshot Restore: If a Tier 2 update causes a service disruption, the pre-patch snapshot will be restored immediately. The failed update will be investigated in a staging environment before being retried.
- Update Log: A record of all updates applied, their dates, and any observed issues will be maintained. This log serves both as a change audit trail and as a reference for diagnosing post-patch problems.

5. Data Protection

5.1 Encryption at Rest

- Full Disk Encryption (LUKS): Full disk encryption will be implemented using LUKS (Linux Unified Key Setup) at the block device level. If physical access to the server hardware is obtained by an unauthorized party, all data on the drive is unreadable without the decryption key. This directly addresses the physical access scenario described in Section 1.
- Key Attribution: Encryption keys are individually attributed, each administrator's access credentials are tied to their identity. If an individual's access is revoked, their key material is invalidated without affecting others. This extends the non-repudiation principle from authentication into data access.

5.2 File Permission Strategy

- Configuration Files: Application configuration files containing database credentials, API keys, and other secrets will be owned by the application's service account and set to owner-read-only (chmod 600 or 640). These files will not be world-readable under any circumstances.
- Log Files: Log files will be readable by administrators and the logging daemon only. The web application's service account will not have read access to audit logs, preventing an attacker who compromises the application from reading or tampering with evidence of their intrusion.
- Web Application Files: Web application files will be owned by the web server's service account. The web server process will have read access to serve files but will not have write permissions. Administrative writes to application files require explicit admin credentials, preventing a web-based exploit from modifying application code.
- No Sensitive Data on Personal Systems: No data classified as sensitive (PII, credentials, financial records, or proprietary project data) will be stored on personal administrator devices or unsanctioned external storage.

6. Logging, Monitoring, and Auditing

6.1 Log Sources

- Authentication Logs (/var/log/auth.log): Records every SSH login attempt (successful and failed), sudo command execution, account switches, and authentication failures. This is the

primary source for detecting brute force attacks, unauthorized access attempts, and insider privilege abuse.

- **Web Server Access and Error Logs:** Records every HTTP/HTTPS request including source IP, requested URL, response code, and user agent. Anomalous patterns (repeated 404 errors, requests targeting administrative paths, or unusually long URLs) may indicate active reconnaissance or exploitation attempts.
- **System Logs (/var/log/syslog, journald):** Records service starts and stops, kernel messages, and hardware events. Unexpected service crashes or restarts may indicate an active exploit or misconfiguration.
- **Auditd Security Logs:** Provides fine-grained tracking of file access, privilege escalation, and system calls. Particularly valuable for detecting a malicious insider reading files outside their normal operational scope.
- **Package and Update Logs:** Records all packages applied, their versions, and timestamps. Provides a reference point for diagnosing post-patch problems and satisfies change audit requirements.

6.2 Review Cadence

- **Automated Alerting (fail2ban):** fail2ban will be configured to automatically detect repeated authentication failures and block offending IP addresses after a defined threshold. This addresses the constant background noise of brute force scanning without requiring manual intervention.
- **Weekly Admin Review:** A designated administrator will review authentication logs and web access logs on a weekly basis, looking for anomalies not caught by automated tools.
- **Event-Triggered Review:** Any automated alert, account modification, privilege escalation outside normal scope, or post-patch anomaly triggers an immediate log review by the on-call administrator.

6.3 Suspicious Activity Indicators

- **Brute Force Pattern:** Dozens of failed SSH attempts from a single IP in a short window
- **Anomalous Authenticated Session:** Successful login at an unusual hour or from an unfamiliar IP, followed by privilege escalation or access to files outside the user's normal scope.
- **Insider Abuse Indicators:** sudo commands outside an administrator's defined role, or auditd events showing access to sensitive configuration files or logs by an account not normally associated with those files.
- **Ransomware or Post-Exploitation Indicators:** Mass file read/write events, creation of new scheduled tasks or services, or unexpected outbound network connections to unknown external addresses.

7. Hardening Checklist

The following checklist defines the minimum set of actions required before the server is considered production-ready.

Access and Authentication

- ☐ Disable root SSH login in /etc/ssh/sshd_config (PermitRootLogin no)

- ☐ Disable password authentication in sshd_config (PasswordAuthentication no)
- ☐ Configure AllowUsers in sshd_config to explicitly list authorized admin accounts only
- ☐ Create individual named admin accounts; confirm no shared accounts exist
- ☐ Scope sudo privileges per admin role in /etc/sudoers.d/; confirm no NOPASSWD blanket grants
- ☐ Lock or remove default and unused system accounts

Services and Attack Surface

- ☐ Disable and remove unnecessary services: Postfix, Avahi, Bluetooth, FTP daemon
- ☐ Confirm only SSH, web server, UFW, and logging daemons are active (systemctl list-units)
- ☐ Confirm no GUI or graphical remote access tools are installed
- ☐ Confirm SFTP is available via SSH; no separate FTP service running

Firewall and Network

- ☐ Enable UFW with default-deny inbound policy
- ☐ Open only ports 22 (SSH), 80 (HTTP), and 443 (HTTPS)
- ☐ Verify no unexpected open ports via port scan before go-live

Data Protection and Permissions

- ☐ Confirm LUKS full disk encryption is active and key attribution is documented
- ☐ Confirm application config files are owner-read-only (600 or 640); not world-readable

Patching and Logging

- ☐ Configure unattended-upgrades for security-only automatic updates
- ☐ Define and document maintenance window schedule and rollback procedure
- ☐ Confirm auditd is installed, configured, and writing to log files
- ☐ Confirm fail2ban is installed and configured for SSH brute force protection
- ☐ Confirm web server access and error logging is active and writing correctly

Appendix: Administrator Acceptable Use Policy

The following policy applies to all individuals with administrative access to organizational server infrastructure. Compliance is mandatory. Violations may result in immediate access revocation and disciplinary action.

- **No Credential Sharing:** SSH keys and account credentials are issued to named individuals and must never be shared, transferred, or duplicated to unsanctioned devices or storage. Each administrator is personally accountable for all actions performed under their credentials.
- **Key Security:** Private SSH keys must be stored securely on issued or approved devices only. Keys must not be copied to personal cloud storage, personal computers, or removable media without explicit authorization.
- **Immediate Reporting of Compromised Devices:** If a device holding a private SSH key is lost, stolen, or suspected of compromise, this must be reported immediately to the team so the associated key can be revoked. Delayed reporting will be treated as a policy violation regardless of intent.

- **No Unauthorized Software Installation:** Only approved administrators may install software on organizational servers. All installations must occur within the defined maintenance window unless a documented emergency justifies an exception.
- **Change Notification Required:** All non-emergency changes must be communicated to the administrative team before implementation. Unannounced changes are indistinguishable from malicious activity and will be treated as security incidents pending investigation.
- **All Actions Are Logged and Observable:** All administrative actions are captured in system and audit logs. Physical access to server hardware is subject to physical surveillance. Administrators should assume all actions are observable and attributable at all times.
- **No Sensitive Data on Personal Systems:** Organizational data (including credentials, configuration files, PII, and any proprietary information) must not be stored on personal devices or unsanctioned storage systems. Violations constitute a potential data breach.
- **Malicious Behavior Results in Immediate Revocation:** Any administrator found abusing access privileges, tampering with audit logs, or operating outside their defined role will have all credentials revoked immediately pending formal investigation.